Part 11 Brief · Assurance and supply chain

mcp-ops-server · 21 Oct 2026 · PR #24 · Status: in review; Codex (2x P1, 7x P2) fixed · HIPAA-ready, never compliant

WHAT WAS BUILT

- **A controls matrix** (`docs/hipaa-controls.md`): all 12 standards and specifications of 45 CFR 164.312, each with a status (Addressed, Partly, Adopter), the tests that prove it, and what stays with the adopter. **A STRIDE threat model** (`docs/threat-model.md`): 17 threats on the agent, server and backend path, including prompt injection through tool results. `SECURITY.md`.
- **mcp-ops-kit as its own package**, released to PyPI from a tag on main by trusted publishing (no API token anywhere). **Signed images** with a signed SPDX SBOM. **CodeQL, Dependabot**, and every action pinned by commit.

HOW IT WORKS

Piece	What runs, and where
check_docs.py (CI test job)	every test, file and terraform run the docs cite must exist; every spec and STRIDE category present; no 'compliant' claim
package job (every PR)	build sdist, then wheel from it; only the kit inside; twine --strict; the wheel alone in a fresh venv, used
container job (every PR)	local registry + throwaway key: SBOM, sign, attest, verify; another key and an attest-only image must fail
publish job (main only)	keyless signature as `ci.yml@refs/heads/main`, SBOM attested, both verified before latest moves
release-kit.yml (kit-v* tag)	tag on main, matching __version__, every CI job + CodeQL green on it; then your approval in the pypi environment

WHY IT WAS DONE THIS WAY

- **Docs that CI checks.** A matrix that cites tests goes stale the day a test is renamed; now that fails the build. **The PR tests the signing plumbing** with a key, because a keyless identity exists only on main.
- **cosign and syft built by go install**, checked against Go's checksum database: this session could not reach GitHub releases, and the same commands then run identically here and in CI.

WHAT WENT WRONG OR SURPRISED ME (LOGGED IN FAILURES.MD)

- **cosign v3's** `verify` **passed an image that was never signed**, only attested. My script now requires the image-signature payload for that digest, and CI proves an attest-only image is refused.
- **v3 dropped** `--tlog-upload=false` (a signing config with no log replaces it). **The secret scanner ran** `gitleaks:latest`; it is pinned by digest now, and a test fails on any unpinned action or image.
- **Codex found my guards inside what they guard:** a tag runs its own copy of the release workflow, so the boundary is now your environment reviewer and tag ruleset; releases need CI green on the commit. It also caught claims broader than their tests, plain-HTTP FHIR accepted by the server (now refused), setuid binaries in the image (stripped, scanned in CI), and a restored database file passing silently (now a stated residual).

VERIFY IT YOURSELF

```
python scripts/check_docs.py && pytest -q                    # 607 passed
pip install build && python scripts/build_kit.py --out /tmp/kit
python scripts/check_kit_dist.py check /tmp/kit
scripts/supply_chain.sh verify ghcr.io/nikhilll30/mcp-ops-server@sha256:<digest>  # after merge
```

INTERVIEW TALKING POINT

"I wrote a test where the image was only attested, never signed, and cosign said it was signed. So my verify checks the payload type, and CI runs that must-fail case on every PR. A security check you have not seen fail is a guess."

NEXT (YOUR ACTIONS)

Create the **pypi** environment with yourself as required reviewer, a **kit-v*** tag ruleset, private vulnerability reporting and the PyPI pending publisher (STATUS.md); merge; tag **kit-v0.1.0**. Then say **go** for Part 12.